

Introdução a DevSecOps

Integrando Segurança no S-SDLC com
uma Pipeline Open Source

Profissional formado em Análise e Desenvolvimento de Sistemas (IFPE), com 6 anos de experiência em tecnologia — 4 deles com foco em **segurança de aplicações**.

Atuação técnica com Python, automação, segurança e desenvolvimento web (Django, VBA), além de **experiência prática em SAST, DAST, modelagem de ameaças e pentests**.

Palestrante em cibersegurança em instituições como UPE, UNICAP e IFPE, além de eventos como Rec'n'Play e The Developer's Conference (TDC).



Lucas Meira

Application Security Engineer

in/lucasrenaa



DCPT

Desec Certified Penetration Tester



AWS

AWS Cloud Practitioner



ISFS

Information Security Foundation based on ISO IEC 27001



eJPT

eLearnSecurity Junior Penetration Tester



CAP

Certified Appsec Practitioner



EWPTx v3

Web Application Penetration Tester eXtreme



OSWE

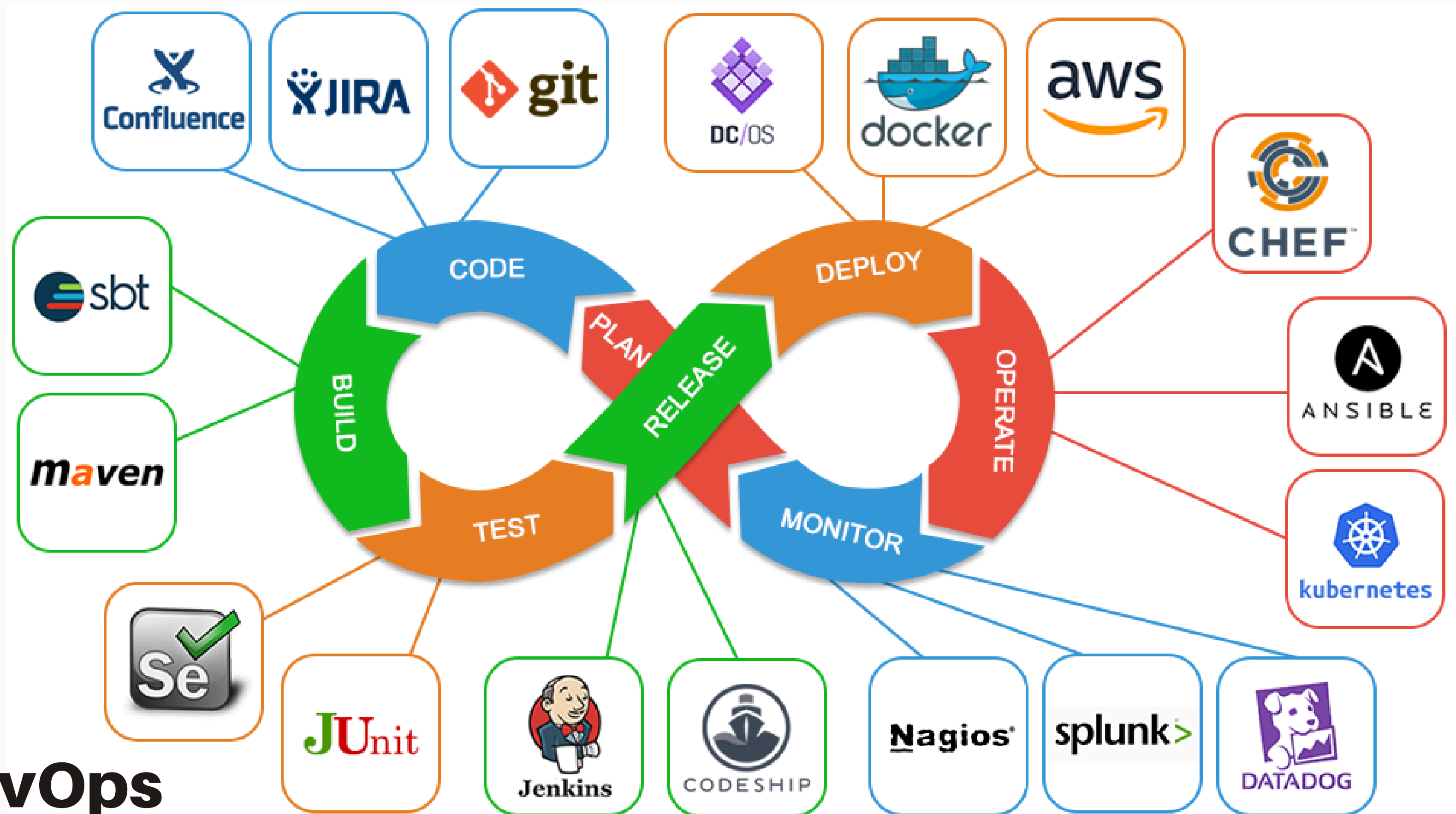
OffSec Web Expert (In Progress)

Tópicos

- Contexto
- DevOps x DevSecOps: Qual a Diferença?
- Componentes de Segurança em DevSecOps
- Integração de Segurança no Pipeline
- PoC: Pipeline DevSecOps na Prática

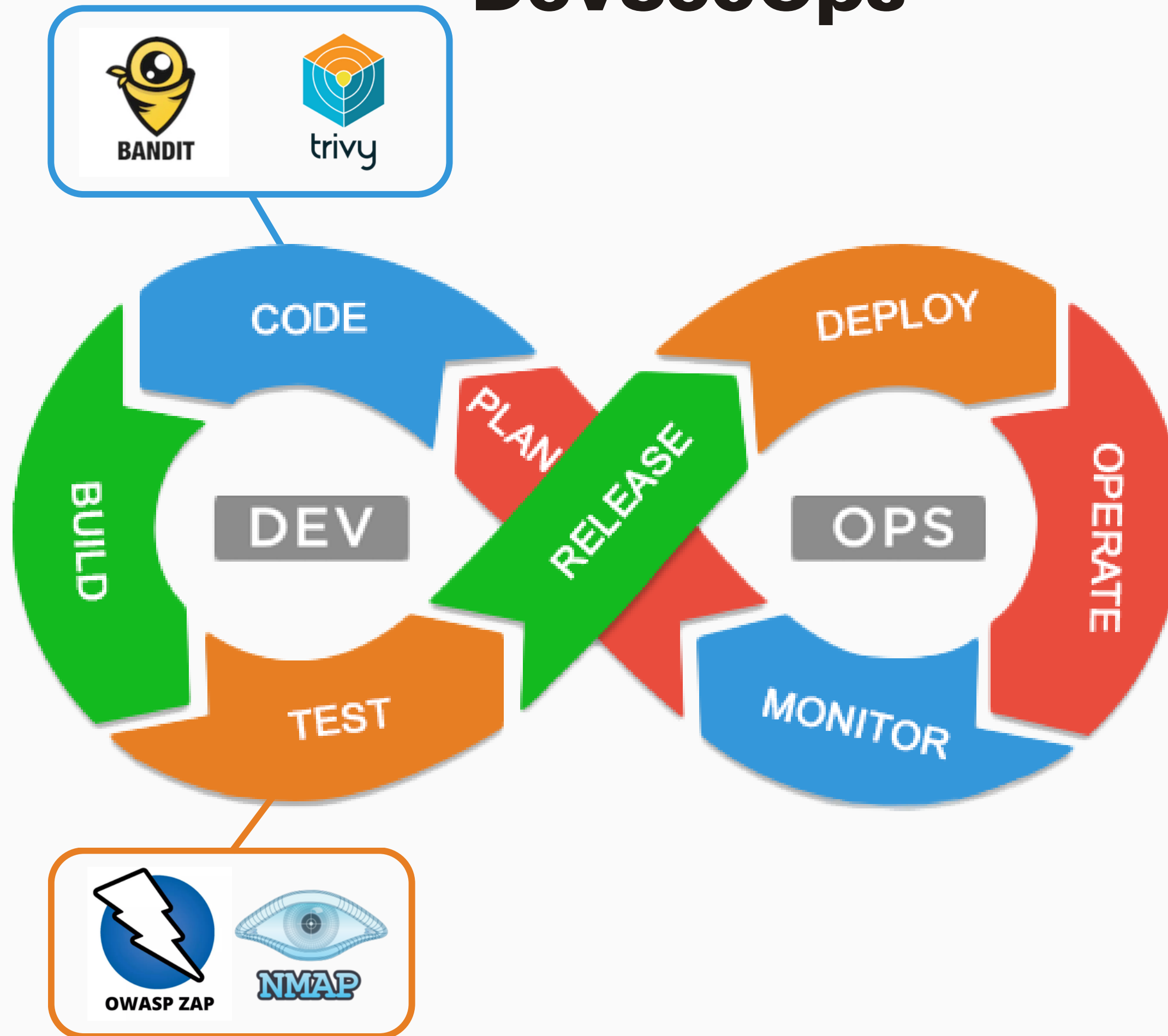
**Um pouco de
contexto...**

DevOps



***“E onde entra
a segurança?”***

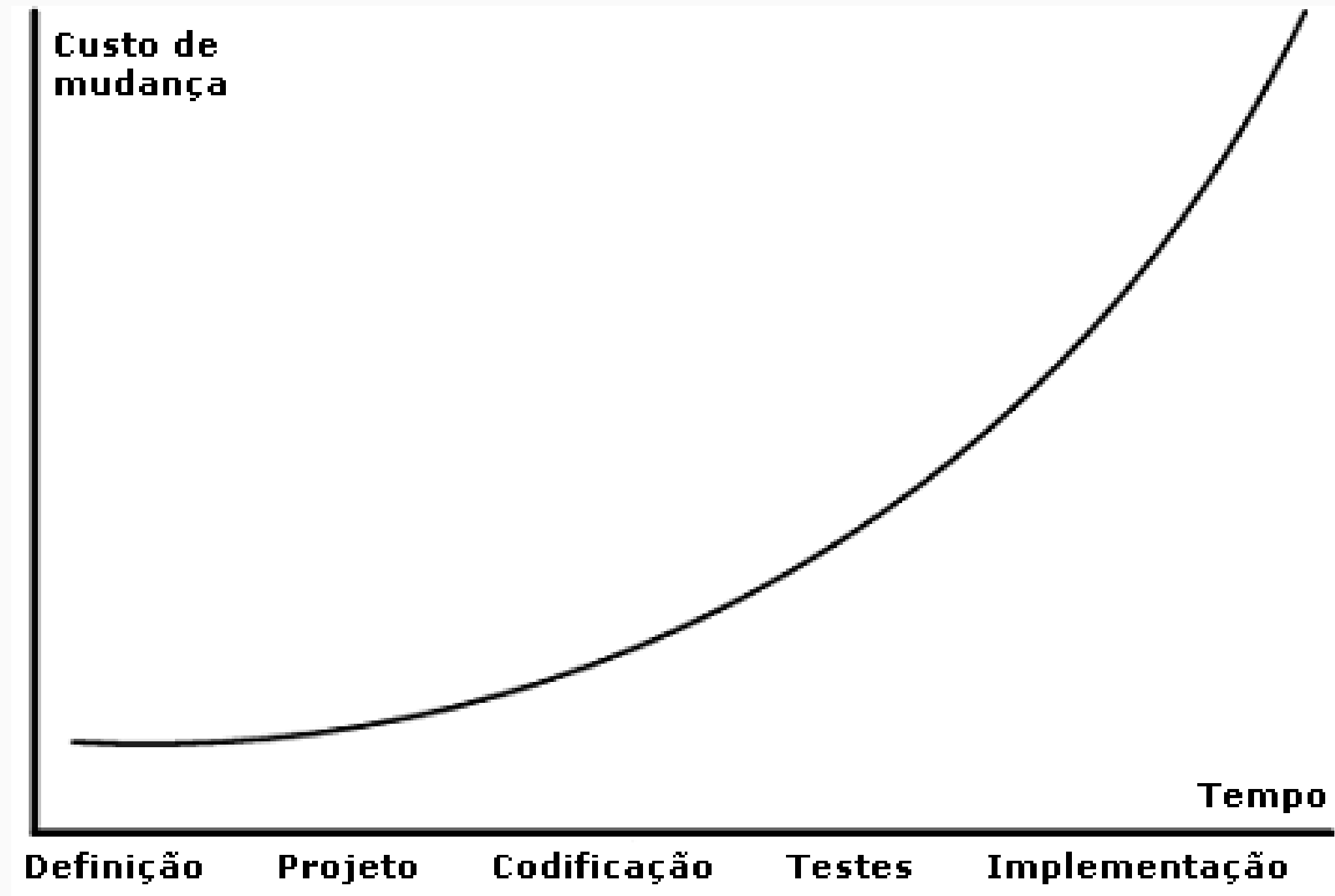
DevSecOps

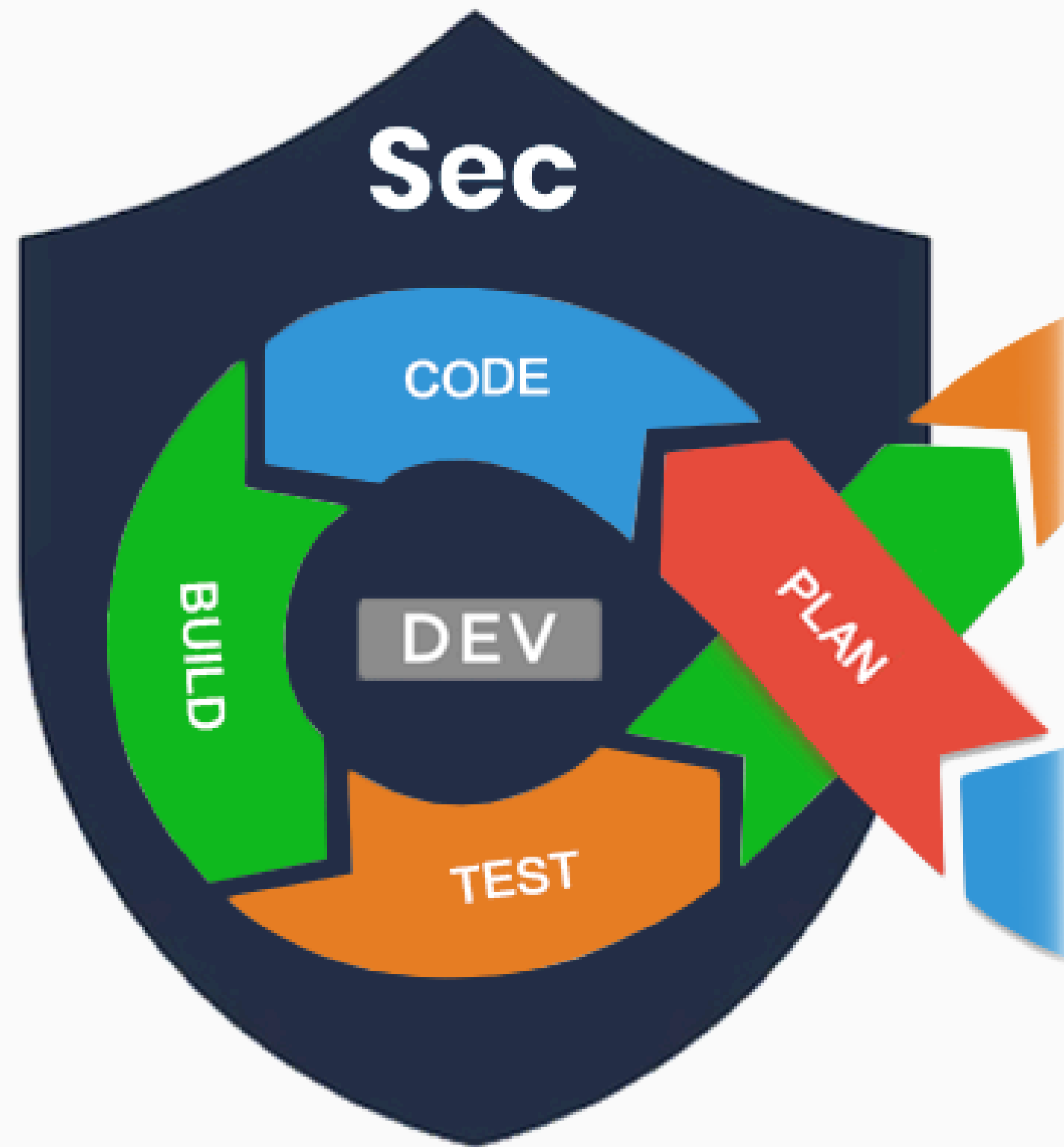


DevOps x DevSecOps

- Segurança no início do desenvolvimento
- Entrega rápida sem comprometer segurança
- Time focado em performance, entrega contínua e segurança integrada.

Por que implementar segurança no ciclo de software:





**Essa
abordagem é
também
chamada de
S-SDLC**

Secure Software Development Lifecycle

**Como implementar
segurança?**

Metodologias

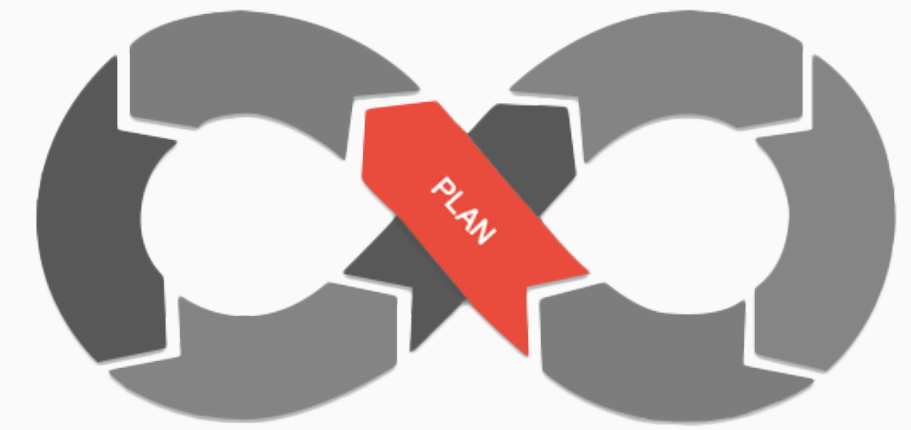
- MASVS
- ASVS

Profissionais envolvidos

- **AppSec (Application Security Engineer)**
- Dev (Software Engineer)
- SRE (Site Reliability Engineer)
- DBRE (Database Reliability Engineer)
- PO (Product Owner)
- etc...

Atividades de um AppSec

Modelagem de Ameaças



- Requisitos de segurança
- Ameaças identificadas
- Potenciais vulnerabilidades (*ainda não exploradas*)



OWASP Threat
Dragon

Microsoft Threat
Modeling Tool

Planilhas de Apoio
(Excel)



A04:2021 - Insecure Design

Sistema com STRIDE

Owner:
Reviewer:
Contributors:
Date Generated: Thu May 29 2025



OWASP Threat Dragon



Executive Summary

High level system description

Not provided

Summary

Total Threats	6
Total Mitigated	0
Total Open	6
Open / Critical Severity	1
Open / High Severity	3
Open / Medium Severity	2
Open / Low Severity	0



Tela de login

Usuário (Actor)

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations
1	Usuário se passando por outro (Spoofing)	Spoofing	High	Open		Usuário tenta se passar por outro utilizando credenciais roubadas.	Implementar autenticação multifator (MFA).

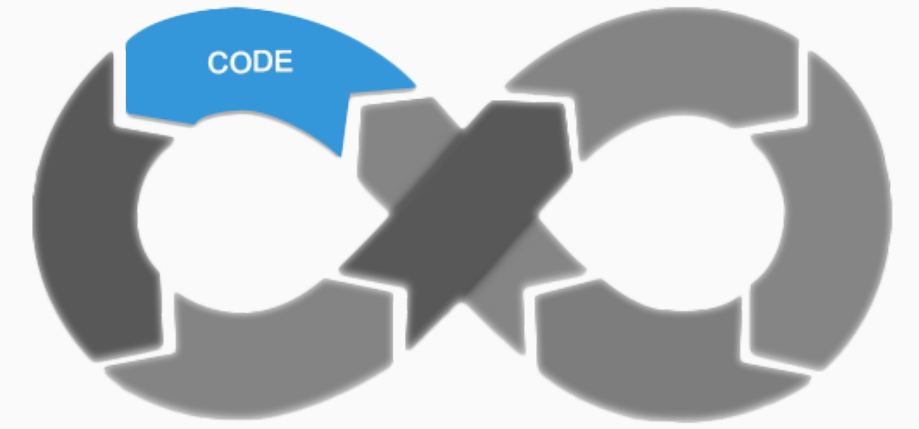
Tela de login (Process)

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations
2	Alteração de parâmetros (Tampering)	Tampering	Medium	Open		Parâmetros da requisição podem ser alterados por um atacante.	Validar e sanitizar todos os dados recebidos do cliente.



Code Review (SCA)



- Análise de vulnerabilidades em bibliotecas



Trivy

Sonarqube

Snyk

Fortify



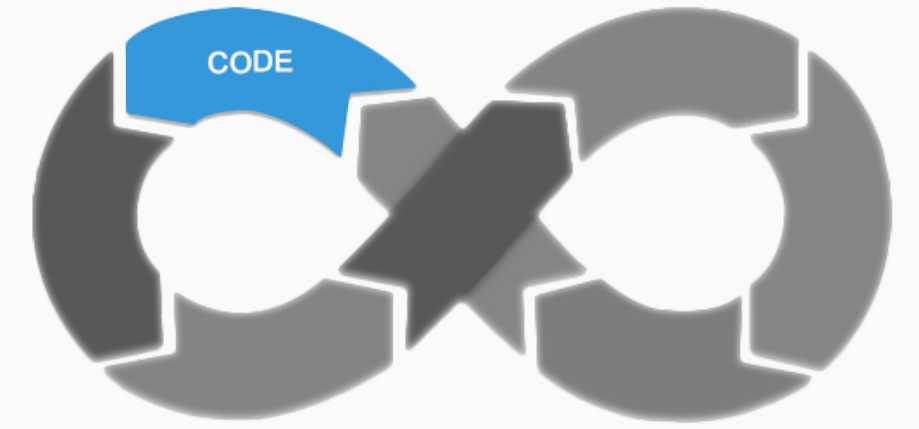
A06:2021 - Vulnerable and Outdated Components

requirements.txt (pip)

Total: 15 (UNKNOWN: 0, LOW: 0, MEDIUM: 8, HIGH: 6, CRITICAL: 1)

Library	Vulnerability	Severity	Status	Installed Version	Fixed Version	Title
Django	CVE-2021-35042	CRITICAL	fixed	3.0.3	3.2.5, 3.1.13	django: potential SQL injection via unsanitized QuerySet.order_by() input https://avd.aquasec.com/nvd/cve-2021-35042
	CVE-2020-13254	HIGH			2.2.13, 3.0.7	django: potential data leakage via malformed memcached keys https://avd.aquasec.com/nvd/cve-2020-13254
	CVE-2020-24583				2.2.16, 3.0.10, 3.1.1	django: incorrect permissions on intermediate-level directories on Python 3.7+ https://avd.aquasec.com/nvd/cve-2020-24583
	CVE-2020-9402				1.11.29, 2.2.11, 3.0.4	django: potential SQL injection via "tolerance" parameter in GIS functions and aggregates... https://avd.aquasec.com/nvd/cve-2020-9402
	CVE-2021-31542				2.2.21, 3.1.9, 3.2.1	django: Potential directory-traversal via uploaded files https://avd.aquasec.com/nvd/cve-2021-31542
	CVE-2021-33571				2.2.24, 3.1.12, 3.2.4	django: Possible indeterminate SSRF, RFI, and LFI attacks since validators accepted leading... https://avd.aquasec.com/nvd/cve-2021-33571
	CVE-2022-36359				3.2.15, 4.0.7	An issue was discovered in the HTTP FileResponse class in Django 3.2... https://avd.aquasec.com/nvd/cve-2022-36359
	CVE-2020-13596	MEDIUM			2.2.13, 3.0.7	django: possible XSS via admin ForeignKeyRawIdWidget https://avd.aquasec.com/nvd/cve-2020-13596
	CVE-2020-24584				2.2.16, 3.0.10, 3.1.1	django: permission escalation in intermediate-level directories of the file system cache on... https://avd.aquasec.com/nvd/cve-2020-24584
	CVE-2021-28658				2.2.20, 3.0.14, 3.1.8	django: potential directory-traversal via uploaded files https://avd.aquasec.com/nvd/cve-2021-28658
						django: potential directory-traversal via uploaded files https://avd.aquasec.com/nvd/cve-2021-28658

Code Review (SAST)



- Senhas em códigos
- Sanitização de dados
- Configurações incorretas de segurança



Trivy

Sonarqube

Snyk

Fortify

Bandit



A03:2021 - Injection

```
-----
>> Issue: [B106:hardcoded_password_funcarg] Possible hardcoded password: 'secret_key'
    Severity: Low    Confidence: Medium
    Location: views.py:640
    More Info: https://bandit.readthedocs.io/en/latest/plugins/b106\_hardcoded\_password\_funcarg.html
639         if valid:
640             client = nexmo.Client(key='key', secret='secret_key')
641             text='Your child ' + data + " arrived school at " + str(datetime.datetime.now())
-----
```

Code scanned:

```
    Total lines of code: 559
    Total lines skipped (#nosec): 0
```

Run metrics:

```
    Total issues (by severity):
        Undefined: 0.0
        Low: 2.0
        Medium: 0.0
        High: 0.0
    Total issues (by confidence):
        Undefined: 0.0
        Low: 0.0
        Medium: 1.0
        High: 1.0
```

Files skipped (0):

DAST

- Análise de vulnerabilidades



Nessus

Nmap

Nuclei

Owasp Zap

Test

CURRENT RESULTS: MAY 11 AT 10:34 PM

Configure

Audit Trail

Launch ▼

Export ▼



Filter Vulnerabilities ▼

Hosts > 192.168.56.102 > Vulnerabilities 41

Compliance 217

☐	Severity ▲	Plugin Name	Plugin Family	Count
☐	CRITICAL	CentOS 6 / 7 : openssl (CE...	CentOS Local Security Checks	1
☐	CRITICAL	CentOS 7 : glibc (CESA-201...	CentOS Local Security Checks	1
☐	HIGH	CentOS 7 : graphite2 (CESA...	CentOS Local Security Checks	1
☐	HIGH	CentOS 7 : kernel (CESA-20...	CentOS Local Security Checks	1
☐	HIGH	CentOS 7 : mariadb (CESA-...	CentOS Local Security Checks	1
☐	MEDIUM	CentOS 5 / 6 / 7 : bind (CES...	CentOS Local Security Checks	1
☐	MEDIUM	CentOS 6 / 7 : ipa / libldb / ll...	CentOS Local Security Checks	1
☐	MEDIUM	CentOS 6 / 7 : libssh2 (CES...	CentOS Local Security Checks	1
☐	MEDIUM	CentOS 6 / 7 : nss-util (CES...	CentOS Local Security Checks	1
☐	MEDIUM	CentOS 6 / 7 : samba (CES...	CentOS Local Security Checks	1
☐	MEDIUM	CentOS 6 / 7 : libssh2 (CES...	CentOS Local Security Checks	1

Host Details

IP: 192.168.56.102
DNS: st91.i
MAC: 08:00:27:db:3e:a2
OS: Linux Kernel
3.10.0-327.4.5.el7.x86_64 on
CentOS Linux release 7.2.1511
(Core)
Start: May 11 at 10:34 PM
End: May 11 at 10:39 PM
Elapsed: 6 minutes
KB: [Download](#)

Vulnerabilities



Automatizando com Github Actions

Vamos pôr a mão na massa!

O que é o Github Actions?

<> Code

Issues

Pull requests 1

Actions

Projects

Wiki

Security 11

Insights

Settings

Actions

New workflow

All workflows

Analyze GitHub Security Findings

Analyze Pull Request with AI

Full Security Scan

Gerar resposta com TinyLlama

Sarif upload workflow

Security Scan with Trivy

Management

Caches

Attestations

Runners

All workflows

Showing runs from all workflows

Filter workflow runs

Help us improve GitHub Actions

Tell us how to make GitHub Actions work better for you with three quick questions.

Give feedback

389 workflow runs

Event Status Branch Actor

test password fake

Analyze GitHub Security Findings #92: Pull request #7 synchronize by LUCASRENAA

teste5

4 days ago

7m 57s

test password fake

Analyze Pull Request with AI #77: Pull request #7 synchronize by LUCASRENAA

teste5

4 days ago

3m 25s

← Full Security Scan

✓ test password fake #116

Re-run all jobs



Summary

Jobs

✓ Run Security Scans (Trivy + Band...

Run details

Usage

Workflow file

Annotations

1 error

Run Security Scans (Trivy + Bandit + ZAP)

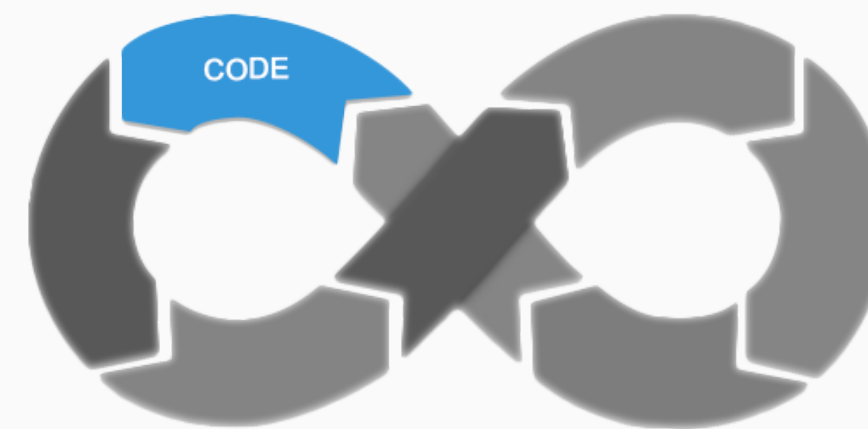
succeeded 4 days ago in 7m 34s

Search logs



- > ✓ Set up job7s
- > ✓ Build aquasecurity/trivy-action@0.20.05s
- > ✓ Checkout repository0s
- > ✓ Set up Python0s
- > ✓ Install dependencies6s
- > ✓ Instalar jq12s
- > ✓ Run Trivy vulnerability scanner5s

Análise estática



SCA

SAST



Trivy

Bandit

SCA - Trivy

[Issues](#) [Pull requests](#) 1 [Actions](#) [Projects](#) [Wiki](#) [Security](#) 11 [Insights](#) [Settings](#)

[Code scanning alerts](#) / #3

python-django-filter: Maliciously input using exponential format may cause denial of service

Dismiss alert ▾

Open

 in `main` on Apr 13

requirements.txt:1

1 # Django com CVE-2022-34265, CVE-2021-44420

Package: django-filter
Installed Version: 2.2.0
Vulnerability CVE-2020-15225
Severity: HIGH
Fixed Version: 2.4.0
Link: [CVE-2020-15225](#)

Trivy

2 `django==2.2.28`
3
4 # djangorestframework com CVE-2021-28359

Tool	Rule ID
Trivy	CVE-2020-15225

Severity

High

Affected branches

main

default

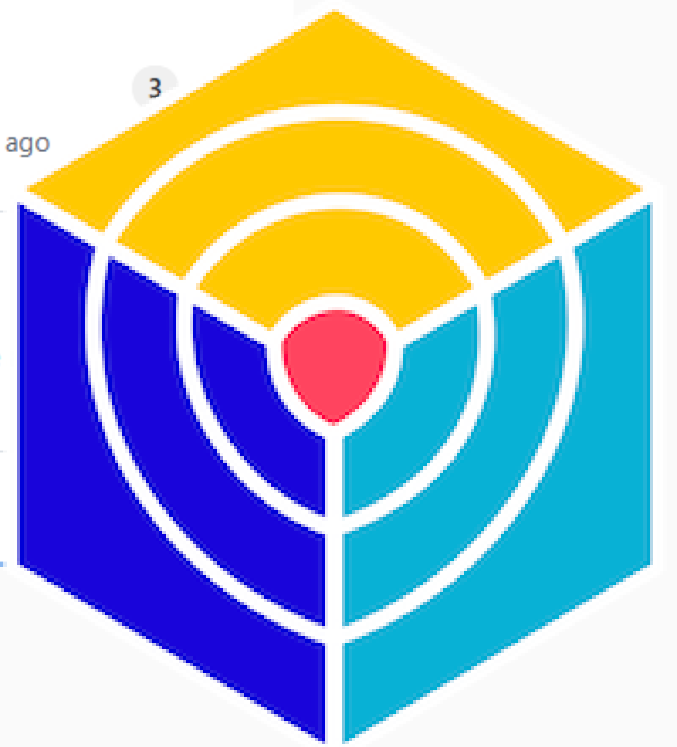
First detected about 2 months ago

Development

Link a branch, pull request, or [create](#) to start working on this alert.

Tags

[high](#) [security](#) [vulnerability](#)



SAST - Bandit

[Issues](#) [Pull requests](#) **1** [Actions](#) [Projects](#) [Wiki](#) **Security** **11** [Insights](#) [Settings](#)

[Code scanning alerts](#) / #25

Possible hardcoded password: 'django-insecure-\$t3crb+e)gopgl7=nb5wvz(-xf\$!v(1meo)voc+l5!7-x59t@5'

Dismiss alert ▾

Open

 in `main` on Apr 13

./core/settings.py:88

Preview unavailable

Sorry, we couldn't find this file in the repository.

Possible hardcoded password: 'admin'

Bandit

Tool	Rule ID
Bandit	B105

Possible hardcoded password: 'django-insecure-\$t3crb+e)gopgl7=nb5wvz(-xf\$!v(1meo)voc+l5!7-x59t@5'

Severity

Warning

Affected branches

main

default

First detected about

Development

Link a branch, pull request, or [create a new branch](#) to start working on this alert.



Análise estática

SCA



```
# ----- TRIVY -----  
- name: Run Trivy vulnerability scanner  
  uses: aquasecurity/trivy-action@0.20.0  
  with:  
    scan-type: 'fs'  
    scan-ref: '.'  
    format: 'sarif'  
    limit-severities-for-sarif: false  
    output: 'trivy-results.sarif'  
  
- name: Upload Trivy SARIF results  
  uses: github/codeql-action/upload-sarif@v3  
  with:  
    sarif_file: trivy-results.sarif
```

SAST



```
# ----- BANDIT -----  
- name: Run Bandit scan  
  run: |  
    bandit -r . -f json -o bandit.json || true  
  
- name: Convert Bandit JSON to SARIF  
  run: |  
    python scripts/bandit_to_sarif.py  
  
- name: Upload Bandit SARIF results  
  uses: github/codeql-action/upload-sarif@v3  
  with:  
    sarif_file: bandit-results.sarif
```

Análise estática

SCA



```
# ----- TRIVY -----  
- name: Run Trivy vulnerability scanner  
  uses: aquasecurity/trivy-action@0.20.0  
  with:  
    scan-type: 'fs'  
    scan-ref: '.'  
    format: 'sarif'  
    limit-severities-for-sarif: false  
    output: 'trivy-results.sarif'  
  
- name: Upload Trivy SARIF results  
  uses: github/codeql-action/upload-sarif@v3  
  with:  
    sarif_file: trivy-results.sarif
```

SAST



```
# ----- BANDIT -----  
- name: Run Bandit scan  
  run: |  
    bandit -r . -f json -o bandit.json || true  
  
- name: Convert Bandit JSON to SARIF  
  run: |  
    python scripts/bandit_to_sarif.py  
  
- name: Upload Bandit SARIF results  
  uses: github/codeql-action/upload-sarif@v3  
  with:  
    sarif_file: bandit-results.sarif
```

IA no pipeline!

Summary

Jobs

✓ Analisar Findings de Seguranç...

Run details

Usage

Workflow file

Analisar Findings de Segurança com TinyLlama

succeeded 4 days ago in 7m 53s

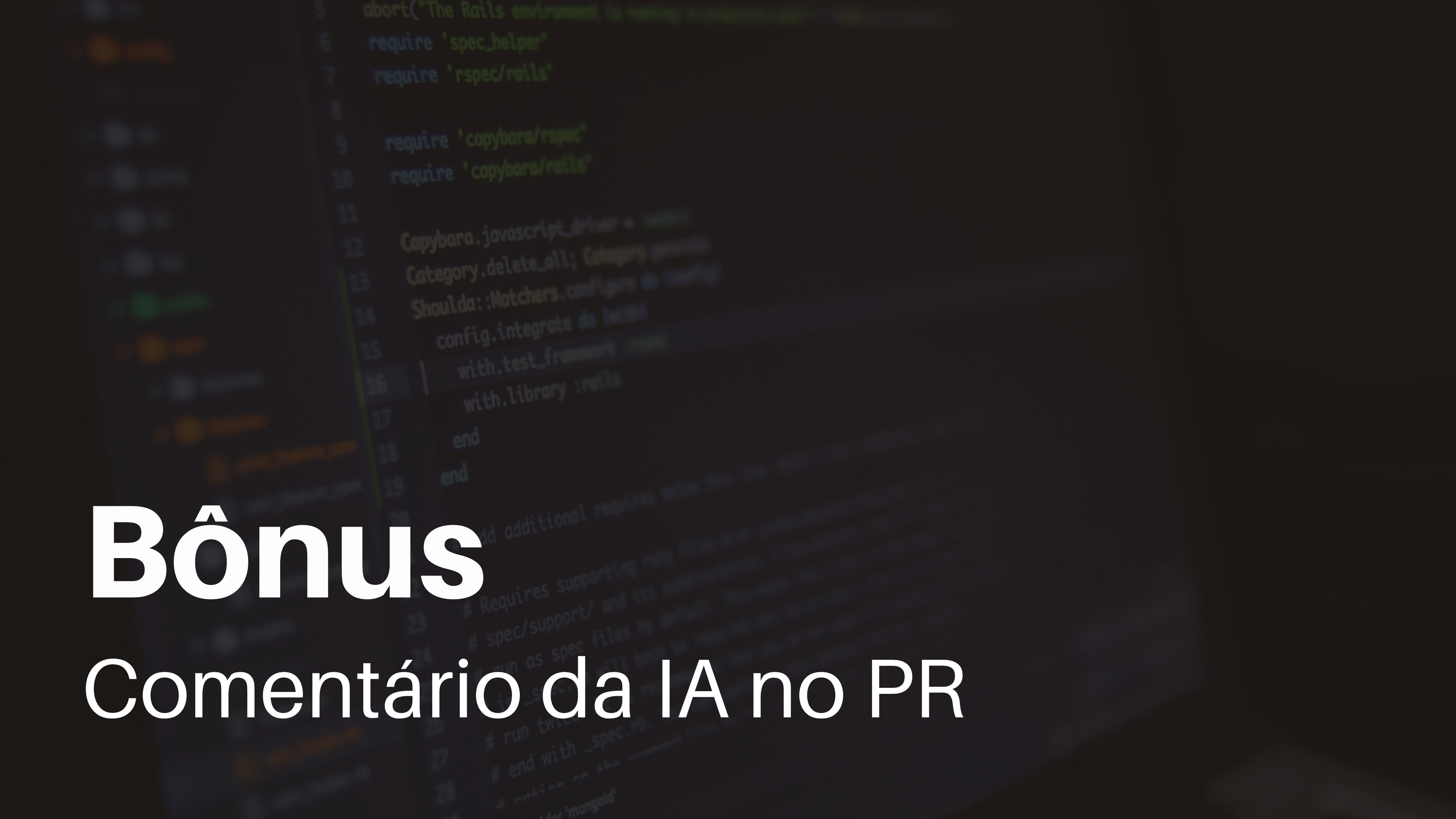
Search logs



✓ Analisar cada finding com TinyLlama

3m 40s

```
1 ▶ Run analyze_findings() {
94 🔍 Analisando findings de code-scanning...
95 🔍 Enviando prompt para o TinyLlama: A vulnerability was found in the repository. Below are the details:
96
97     - Finding ID: 25
98     - Severity: warning
99     - File Path: ./core/settings.py
100    - Line Number: 88
101    - Message: Possible hardcoded password: 'admin'
102
103    Do you consider this a false positive? Justify your answer briefly.
104
105    For reference, here is the rule documentation: https://bandit.readthedocs.io/en/latest/plugins/index.html
106    GitHub Finding Link: https://github.com/LUCASRENAA/BsidesApresenta-o/security/code-scanning/25
107 🔴 Resultado da IA: The finding found in the repository, specifically in the core/settings.py file, is a possible
    hardcoded password. While it's true that this may be considered a false positive by the Bandit rule documentation
    and GitHub findings, it would still require some attention to ensure security measures are in place and potential
    vulnerabilities are addressed. The finding could potentially impact the functioning of the application or its
```

```
5 abort("The Rails environment is running in production mode!")
6 require 'spec_helper'
7 require 'rspec/rails'
8
9 require 'capybara/rspec'
10 require 'capybara/rails'
11
12 Capybara.javascript_driver = :selenium
13 Category.delete_all; Category.create
14 Shoulda::Matchers.configure do |config|
15   config.integrate do |int|
16     | with.test_framework :rspec
17     | with.library :rails
18   end
19 end
20
21 # Requires supporting ruby files with spec support/ and its subdirectories.
22 # spec/support/ and its subdirectories. These files can contain code that will be
23 # run as spec files by default. This is useful if you need to share code
24 # between spec files but it's not recommended to use this for large amounts
25 # of code.
26 # run twice: once to load the code and once to execute the specs.
27 # end with _spec.rb.
28 # option on the command line to run the specs.
```

Bônus

Comentário da IA no PR



github-actions bot commented 4 days ago



Análise Automática da TinyLlama

****Finding #18****

****Severidade:**** warning

****Caminho:**** `./core/settings.py:85`



****Resultado da IA:****

Yes, based on the details provided in the security bulletin, it appears that a possible vulnerability was identified.

[🔗 Ver finding no GitHub](https://github.com/LUCASRENAA/BsidesApresenta-o/security/code-scanning/18)



LUCASRENAA / BsidesApresenta-o

Issues

Pull requests1

Actions

Projects

Wiki

Overview

Reporting

Policy

Advisories

Vulnerability alerts

Dependabot

Code scanning11

Secret scanning

No items to show

+ New card

Code scanning

✓ All tools are working as expected

Tools2+ Add tool

is:open branch:main

11 Open

14 Closed

LanguageToolBranchRuleSeveritySort

python-django-filter: Maliciously input using exponential format may cause denial of service

High

main

#3 opened last month • Detected by Trivy in requirements.txt :1

An issue was discovered in the HTTP FileResponse class in Django 3.2

High

main

#1 opened last month • Detected by Trivy in requirements.txt :1

djangoestframework: Cross-site Scripting (XSS) via break_long_headers

Medium

main

#5 opened last month • Detected by Trivy in requirements.txt :1

django-rest-framework: XSS Vulnerability in API viewer

Medium

main

#4 opened last month • Detected by Trivy in requirements.txt :1

djangoestframework-simplejwt: information disclosure vulnerability

Low

main

#6 opened last month • Detected by Trivy in requirements.txt :1

python-django: Potential user email enumeration via response status on password reset

Low

main

#2 opened last month • Detected by Trivy in requirements.txt :1

Possible hardcoded password: 'django-insecure-St3crb+e)gopgl7=nb5wvz(-xf\$!v(1meo)voc+I5!7-x59t@5'

Warning

main

#24 opened last month • Detected by Bandit in Jcore/settings.py :83

Imagem 1:

Possible hardcoded password: 'django-insecure-\$t3crb+e)gopgl7=nb5wvz(-xf\$!v(1meo)voc+l5!7-x59t@5'

Dismiss alert

Open in main on Apr 14

./core/settings.py:82

Preview unavailable
Sorry, we couldn't find this file in the repository.

Possible hardcoded password: 'admin'
Bandit

Tool	Rule ID
Bandit	B105
Possible hardcoded password: 'django-insecure-\$t3crb+e)gopgl7=nb5wvz(-xf\$!v(1meo)voc+l5!7-x59t@5'	

Severity

Warning

Affected branches

main default

2

First detected about 1 month ago

Development

Link a branch, pull request, or create a new branch to start working on this alert.

First detected in commit on Apr 13 in configuration .github/workflows/only_sarif.yml:security

Merge e391c83 into 9534743

Verified c92d2bc

./core/ settings.py:82 on branch refs/pull/6/merge

Appeared in branch main on Apr 14 in configuration .github/workflows/only_sarif.yml:security

✓ Sarif upload workflow #68: Commit f2106577

Appeared in branch main on Apr 14 in configuration .github/workflows/security.yml:security

✓ Full Security Scan #106: Commit f2106577

Imagem 2:

Próximos passos

- Concluir a funcionalidade em IA para verificar todo o código
- Aprimorar treinamento da IA

Scripts usados

LUCASRENAA/
BsidesApresenta-o



1

Contributor

0

Issues

0

Stars

1

Fork



BsidesApresenta-o/.github/workflows/security.yml at main · LUCASRENAA/BsidesApresenta-o

Contribute to LUCASRENAA/BsidesApresenta-o development by creating an account on GitHub.

 GitHub

LUCASRENAA/
BsidesApresenta-o



1

Contributor

0

Issues

0

Stars

1

Fork



BsidesApresenta-o/.github/workflows/analisar_pr.yml at main · LUCASRENAA/BsidesApresenta-o

Contribute to LUCASRENAA/BsidesApresenta-o development by creating an account on GitHub.

 GitHub

Obrigado! Dúvidas?



Lucas Meira

Application Security Engineer

[in/lucasrenaa](#)

Code scanning alerts / #3

python-django-filter: Maliciously input using exponential format may cause denial of service

 Open in `main` on Apr 13

requirements.txt:1

```
1 # Django com CVE-2022-34265, CVE-2021-44420
```

```
Package: django-filter
Installed Version: 2.2.0
Vulnerability CVE-2020-15225
Severity: HIGH
Fixed Version: 2.4.0
Link: CVE-2020-15225
```

Trivy

```
2 django==2.2.28
```

```
3
```

```
4 # djangorestframework com CVE-2021-28359
```

Tool	Rule ID
Trivy	CVE-2020-15225

Vulnerability CVE-2020-15225

Show more

Dismiss alert

Select a reason to dismiss

- ☐ False positive
This alert is not valid
- ☐ Used in tests
This alert is not in production code
- ☒ Won't fix
This alert is not relevant

Dismissal Reason

Add a comment

Cancel

Dismiss alert

Ativar o Windows

Acesse Configurações para ativar o Windows.